

Robotics Security Platform

The Complete Interview Preparation Guide — Part 1 of 4: Foundations & Architecture

This four-part guide is written so that **if you read only these documents, you can confidently explain the entire project end to end** — what it does, how every piece works, why each design choice was made, and what you would change for production. Everything here is taken from the actual code and configuration in the repository; nothing is invented.

How the four parts fit together

Part	Title	What it covers
1	Foundations & Architecture	The problem, the vocabulary, the six zones, the network, the data flows, the tech stack.
2	The Plant Floor (OT & Safety)	The PLC and its code, the robot, Modbus, ROS2/SROS2 security, and the safety system (heartbeat, watchdog, latched E-stop).
3	The Brain (Detection, AI, Response, DevSecOps)	Network monitoring, the ML anomaly detection, incident response, vulnerability management, the CI/CD pipeline, and the dashboard.
4	Demo, Q&A & Cheat-Sheets	How to run it, the live demo script, likely questions with answers, honest trade-offs, standards mapping, and a glossary.

HOW TO STUDY THIS

Read Part 1 and Part 4 first. Part 1 gives you the mental model the interviewer is testing; Part 4 gives you the words to say and the demo to show. Parts 2 and 3 are the deep technical detail you pull from when they probe.

1. The pitch (memorize these two)

The 30-second version

SAY THIS IN THE INTERVIEW

"It is an intelligent security platform that protects an industrial robot on a smart-manufacturing line. It implements OT/IT convergence security with Purdue-model network segmentation and an industrial DMZ, passively monitors the robot's Modbus and ROS2 traffic with Zeek and Suricata, and runs three machine-learning models to detect cyber-physical attacks in real time. When it detects an attack it can trigger an authenticated emergency stop and run automated incident-response playbooks, while a DevSecOps pipeline validates all the PLC and robot code. It is built entirely from open-source tools and aligned to IEC 62443 and NIST SP 800-82."

The one-sentence version (if they want it shorter)

SAY THIS IN THE INTERVIEW

"A Purdue-zoned OT security lab that detects cyber-physical attacks on a robotic cell with machine learning and responds with an automated, safety-aware incident-response engine."

What each big word means (so you are never caught out)

- **OT/IT convergence** — connecting the factory-floor equipment (OT) to normal computer networks (IT) so data can flow, while keeping them safely separated.
- **Purdue model** — the standard way to divide a factory network into trust levels/zones (more on this in section 4).
- **Cyber-physical attack** — a cyber attack that causes a physical effect: making a real robot arm move wrongly, not just stealing data.
- **Anomaly detection** — the computer learns what "normal" looks like and flags anything that does not fit, instead of looking for known attack signatures.

2. What problem does this project solve?

2.1 IT vs OT — two different worlds

IT (Information Technology) is the world of normal computers: laptops, email, web servers, databases. If an IT system is attacked, the worst case is usually *lost or stolen data*.

OT (Operational Technology) is the world of machines that *do physical things*: robot arms, conveyor belts, valves, motors. These are controlled by special industrial computers. If an OT system is attacked, the worst case is a *machine moving dangerously* — damaging product, the equipment, or a human being.

WHY IT MATTERS

IT security protects information. OT security protects information AND the physical process AND the people standing next to the machine. That is why this project keeps saying "safety always wins."

2.2 Why connecting them is risky (and why we do it anyway)

Factories want OT data (How many parts did we make? Is a motor about to fail?) up in the IT world for dashboards and planning. So they connect the two. The moment you do that, an attacker who gets into the easy IT side could potentially reach the dangerous OT side. **"OT/IT convergence security" is the discipline of getting the data benefits without opening that door.** This whole platform is one worked example of doing it carefully.

PLAIN-ENGLISH EXAMPLE

Think of a hospital. The cafe Wi-Fi (IT) and the life-support machines (OT) might share a building, but you would never let someone on the cafe Wi-Fi reach a ventilator. You put doors, guards, and separate corridors between them. This project builds those doors, guards, and corridors for a robot cell.

2.3 The assignment this was built for (Topic 114)

The project answers an academic brief: build an *intelligent industrial robotics security platform* covering OT/IT convergence, safety-system protection, and AI-driven anomaly detection for smart manufacturing. Every requirement in that brief maps to a real part of this system:

The brief asked for...	This project delivers...
OT/IT convergence, industrial DMZ, microsegmentation	Single-homed zones + a default-deny nftables router (8 conduits), analytics network-enforced read-only to OT, and a Guacamole DMZ jump host.
Secure remote / vendor access	Time-boxed, audited vendor sessions provisioned through an authenticated API into a DMZ jump host.
Network traffic & industrial protocol monitoring	Zeek + Suricata + ntopng passively watching Modbus and ROS2 traffic.
AI anomaly detection + predictive analytics	Three ML models scoring 5-second windows of Modbus behaviour in real time.
Automated response + safety integration	A playbook engine that isolates attackers automatically and asks a human before stopping the robot.
Safety-critical protection (E-stop, SIS, interlocks)	An independent safety supervisor with a heartbeat watchdog and a latched emergency stop.
IEC 62443 / NIST SP 800-82 alignment	Zone-and-conduit segmentation and OT-security practices throughout.
Vulnerability management	Asset inventory, offline CVE correlation, configuration baselines, and a firmware-update workflow.

The brief asked for...	This project delivers...
DevSecOps for industrial automation	A six-gate CI/CD pipeline that checks PLC, HMI, and robot-permission code on every change.
Incident response & recovery + forensics	NIST-style playbooks with evidence capture, approvals, and a deliberate operator reset.

3. The vocabulary you must own

If you can define these ten terms in one plain sentence each, you will sound fluent. Each comes with an everyday analogy.

PLC (Programmable Logic Controller)

A rugged little industrial computer that directly controls machines — it reads sensors and switches motors, valves, and grippers on or off. In this project the PLC software is **OpenPLC**, and its program is written in a language called **Structured Text**.

PLAIN-ENGLISH EXAMPLE

A PLC is like the "brain stem" of the machine: it handles the fast, reflexive "if this sensor, then that motor" actions, over and over, very reliably.

Modbus

The simple, old, extremely common language PLCs speak over the network. It reads and writes numbered "registers" and "coils" (on/off bits). It has **no passwords and no encryption** — anyone who can reach it can command it.

PLAIN-ENGLISH EXAMPLE

Modbus is like a postcard: easy to write, anyone can read it, and there is no signature proving who sent it. That is exactly why we must monitor and isolate it.

ROS2 & DDS (and SROS2)

ROS2 is the modern software framework that runs robots; it sends messages on named "topics" using a transport called **DDS**. **SROS2** is the security layer that adds **X.509 certificates** so only trusted programs can join the robot's conversation.

PLAIN-ENGLISH EXAMPLE

Plain DDS is an open group chat anyone can join. SROS2 turns it into an invite-only chat where every member must show a cryptographic ID card at the door.

HMI / SCADA

The **HMI** (Human-Machine Interface) is the operator's screen with buttons and gauges for the machine. **SCADA** is the broader system that supervises and collects data across the plant.

PLAIN-ENGLISH EXAMPLE

The HMI is the dashboard of a car; SCADA is the whole fleet-management system the company uses to watch all its cars.

Safety system / SIS & E-stop

A **Safety Instrumented System** is a separate, independent guardian whose only job is to force the machine into a safe state when something goes wrong. The **E-stop** (emergency stop) is the big red "halt now" function. A key rule: once tripped, it **latches** — it stays stopped until a human deliberately resets it.

PLAIN-ENGLISH EXAMPLE

The SIS is the lifeguard who only watches for drowning and is allowed to stop everything, no matter what the swimming instructor (the normal controller) is doing.

Purdue model

The classic blueprint for splitting a factory network into **levels/zones** by trust — from the physical machines at the bottom, up through control, supervision, and the business/IT network at the top — with controlled gateways between them.

PLAIN-ENGLISH EXAMPLE

Like a medieval castle: the keep (machines) in the centre, then inner walls, then outer walls, then the town. You cannot walk straight from the town into the keep.

DMZ (Demilitarized Zone)

A buffer network that sits between the trusted OT side and the less-trusted IT side. Nobody crosses directly; they meet in the DMZ through controlled, brokered services.

PLAIN-ENGLISH EXAMPLE

The visitor meeting room at a secure facility: outsiders never roam the building; they meet staff in one monitored room near the entrance.

IEC 62443 / NIST SP 800-82 / NIST SP 800-61

IEC 62443 is the international standard for industrial control-system security (its core idea is "zones and conduits"). **NIST SP 800-82** is the US guide for securing OT. **NIST SP 800-61** is the incident-response lifecycle (detect, contain, eradicate, recover).

PLAIN-ENGLISH EXAMPLE

These are the "building codes" of OT security. Citing them shows you build to recognized standards, not just personal taste.

IDS (Intrusion Detection System) & passive monitoring

Software that watches network traffic and raises alerts on suspicious activity. **Passive** means it only listens to a *copy* of the traffic (a mirror) and never injects anything — so it can never accidentally disturb the plant.

PLAIN-ENGLISH EXAMPLE

A security camera, not a security guard who tackles people. It observes and reports; it cannot trip over the production line.

Anomaly detection vs signatures

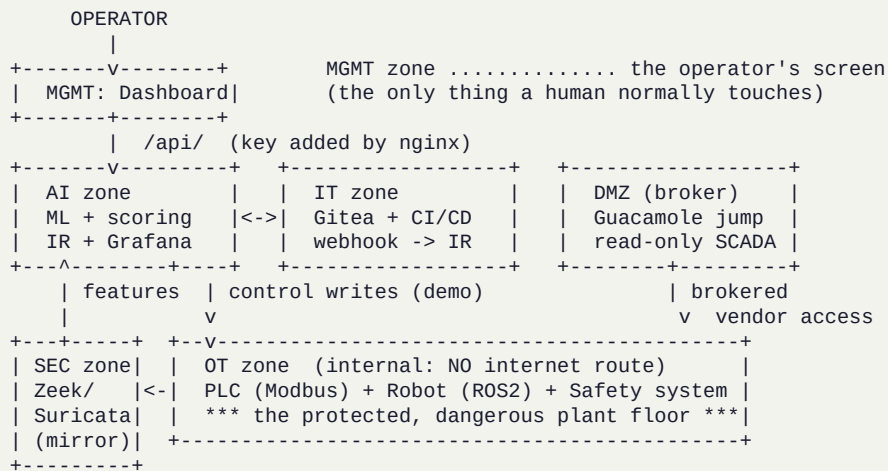
A **signature** detector looks for known-bad patterns (like antivirus). An **anomaly** detector learns what *normal* looks like and flags anything different — so it can catch brand-new attacks that have no known signature.

PLAIN-ENGLISH EXAMPLE

Signatures are a "most wanted" poster (only catches known faces). Anomaly detection is a regular who notices "that person has never been in here before and is acting oddly."

4. The six security zones

The whole system is organised into six zones. Each zone is a level of trust, and the rule is simple: **the more dangerous a zone is, the more isolated it must be**. The plant floor (OT) is the most dangerous, so it is the most locked-down.



Zone	Subnet	What lives there	Why it is placed there
OT	192.168.10.x	PLC, robot (Gazebo+ROS2), safety system	Real-time and safety-critical — must be the most isolated; no internet route.
SEC	(on OT mirror)	Zeek, Suricata, ntopng, vuln tools	Passive monitoring belongs next to OT but must only <i>listen</i> , never inject.
AI	192.168.40.x etc.	Redis, 3 ML models, scoring API, IR engine, Prometheus/Grafana	The heavy "brain" kept off the OT real-time path.
IT	192.168.20.x	Gitea (code repo) + CI/CD runner + webhook	Normal developer tooling; general-purpose, lower trust.
DMZ	192.168.30.x	Guacamole jump host, read-only SCADA monitor	The only place OT and IT are allowed to meet — through brokered services.
MGMT	192.168.40.x	The React dashboard (operator plane)	What the operator actually uses; kept separate from everything else.

WHY IT MATTERS

The zone names map directly onto folders in the repo: **vm-ot**, **vm-sec**, **vm-ai**. That clean separation is a real strength — you can reason about "blast radius" (how far an attacker gets) one zone at a time.

5. Network segmentation (how the zones are kept apart)

Zones are only meaningful if something actually enforces the separation. This build is a **true single-homed IEC-62443 Level-3.5 IDMZ**: four controls do the work.

Control 1 — every service is single-homed; one router is the only node that spans zones

Each container attaches to **exactly one** zone network, so the segmentation is structural rather than advisory. The **only** multi-homed node is a dedicated router/firewall container (Alpine + nftables) at .2 on all four zones, running a **default-deny** forward policy. That is exactly what a firewall is for — and it means a single compromised service cannot bridge two zones.

Control 2 — only eight conduits are open; IT↔OT is impossible

The router drops everything by default and permits just **eight** source→destination:port conduits (read-only proxy, control gateway, vendor RDP, the two signed-deploy flows, CI webhook, read-only wall-board, SEC feature push). **IT→OT matches no conduit on any path**. An automated matrix probes all eight conduits plus key denials — **16 checks, all green**.

Control 3 — the analytics zone is network-enforced read-only to OT

The scoring service has **no Modbus client to the PLC**. It reads telemetry only through an OT-resident **read-only Modbus proxy** (port 5020, forwards reads, rejects writes); any control goes through a separate authenticated **OT control gateway** (port 8002). **AI→raw PLC:502 matches no conduit and is dropped** — the analytics plane physically cannot write to the controller.

Control 4 — the monitor lives inside OT and cannot pivot out

The SEC sensor is **single-homed inside OT** (an OT-resident IDS), because a Docker bridge will not mirror third-party unicast to a passive port — the monitor must be a party to the traffic, like a hardware SPAN tap. It ships ML features to the management Redis over **one conduit scoped to its own IP**, so even a compromised sensor cannot roam the management zone.

SAY THIS IN THE INTERVIEW

"It is a true single-homed IDMZ: every service on one zone, and a default-deny nftables router as the only node allowed to cross zones, through eight explicit conduits. IT cannot reach OT at all, and the analytics plane is network-enforced read-only to the PLC — a read-only proxy for reads, an authenticated OT gateway for control, never raw Modbus. The honest remaining gap is that it is one host compressing what would be per-zone hardware, and the safety controller is still a software simulator."

This enforces **zone-level** segmentation with a real default-deny firewall. The next finer step is **microsegmentation** (per-workload, intra-zone control) — a likely follow-up; **Part 4, section 6** covers exactly what that adds on top of the current router.

6. The two data flows (the heartbeat of the system)

Almost everything in this platform is one of two journeys. If you can draw these two arrows, you understand the system.

6.1 The monitoring flow (data going UP)

This is how an attack becomes an alert. It always flows the same direction: from the plant floor, up to the brain.

```
ROBOT/PLC traffic          (real Modbus on the wire)
  | (1) mirror / SPAN copy
  v
ZEEK + SURICATA -- parse Modbus, extract features --> feature_pusher
  | (2) push feature rows
  v
REDIS list: lab.modbus.features.raw
  | (3) feature_consumer builds a 5-second window
  v
3 ML MODELS score the window --> anomaly? --yes--> REDIS: anomaly.events
  |                                     |
  | (4) alert_bridge writes ai-alerts.json   v
  +-----> DASHBOARD + Prometheus
```

6.2 The control flow (commands going DOWN)

This is how a human acts on the plant. It flows the opposite way: from the operator, down to the machine — and the most dangerous step waits for a human.

```
OPERATOR clicks on the DASHBOARD (MGMT)
  | (1) /api/... request; nginx adds the secret API key server-side
  v
SCORE_SERVICE API (MGMT/analytics zone) -- NO raw Modbus client --
  | reads via OT read-only proxy :5020 | control via OT gateway :8002
  v                                     v (router conduits only)
PRODUCTION PLC :502 <----- OT CONTROL GATEWAY (the only PLC write path)
  | (2) safety supervisor :503 enforces state; mirrored over SROS2
  v
ROBOT freezes at its last safe waypoint when EMERGENCY is latched
```

WHY IT MATTERS

Notice the asymmetry: detection is fully automatic (monitoring flow), but the control flow has a human gate before anything physical happens. "Automated where it is safe, human-approved where it is physical" is the core philosophy — you will repeat this in Part 3.

7. The technology stack & the containers

7.1 Everything is open-source

Area	Tools used
Industrial control	OpenPLC (runs IEC 61131-3 Structured Text), Modbus/TCP
Robotics	ROS 2 Humble, Gazebo simulator, SROS2 + Cyclone DDS (X.509 security)
Network monitoring	Zeek (with Modbus/DNP3/OPC-UA parsers), Suricata, ntopng
Machine learning	scikit-learn (Isolation Forest), TensorFlow-CPU (autoencoder), NumPy
Services / API	Python 3, FastAPI, pymodbus, Redis (message bus)
Dashboard	React + TypeScript + Vite, served by Nginx (with TLS)
Observability	Prometheus (metrics), Grafana (dashboards), a custom lab exporter
Code / CI-CD	Gitea (self-hosted Git), Gitea Actions runner, an HMAC webhook
Remote access	Apache Guacamole (browser-based jump host)
Orchestration	Docker Compose, four Docker bridge networks acting as VLANs

7.2 The eleven containers

The system runs as eleven containers: the custom-built **container-ot**, **container-sec**, **container-ai** and **dashboard**; the stock **gitea**, CI runner, postgres, guacd, guacamole, and historian/artifact-store; and the dedicated **router-fw** — the one node attached to all four zones, enforcing the default-deny firewall.

CHEAT-SHEET (say these with confidence)

Key numbers to memorize: **4 zones** (OT .10 / IT .20 / DMZ .30 / MGMT .40, router at .2 on all), **single-homed** services + **1 router**, **8 conduits** (matrix 16/16), **11 containers**, **4 OT ports** (502 prod, 503 safety, 5020 read-only proxy, 8002 control gateway), **2 detection planes** (3 network models + robot LSTM), a **5-second / 20-feature** window, a **5 Hz heartbeat / ~2 s watchdog**, a **signed pull-deploy**, and **6 CI/CD gates**.

End of Part 1. You now have the mental model: the problem (OT/IT convergence), the vocabulary, the six zones, how they are kept apart, the two data flows, and the stack. **Part 2** goes down onto the plant floor: the PLC code, the robot, Modbus attacks, SROS2, and the safety system that guarantees the robot fails safe.